ProfiNET on the Festo machine

For this assignment I looked at the ProfiNET traffic of the dispense station. I used the Wireshark capture file that was given (festoFactoryWireshark - IO being used.pcapng) and I opened it in Wireshark. Below I answer the parts of the assignment one by one.

1. How ProfiNET works (the basics)

ProfiNET is a network that factories use so a PLC can talk to its sensors and actuators. It runs on normal Ethernet, so it uses the same cables, switches and network cards as a normal computer network. That is handy, but it also means you can read the traffic with Wireshark like any other network.

The main parts are:

- The PLC. This is the boss (the controller). It runs the program and decides what the outputs do.
- The IO device. This is the slave. It reads the inputs (sensors) and sets the outputs (actuators) and sends the values back to the PLC.
- The engineering PC or HMI, used to program and watch the machine.

ProfiNET has a few types of messages. In Wireshark you filter them with pn_. The two important ones are:

- pn_io: the normal data between the PLC and the IO device. These messages are sent all the time, very fast, and they carry the real inputs and outputs.
- pn_dcp: this is used when the PLC searches for devices and gives them a name and IP address. It only happens when you start up or restart a device.

An important point: these pn_io messages are not encrypted and there is no password or signature on them. So anyone on the same network can read them, and also copy them.

2. What I found in the capture (Wireshark monitoring)

I opened the capture and used the filter pn_io. This is what I saw:

- The file has about 116.000 packets over about 115 seconds.
- Almost all of them (about 99 percent) are ProfiNET real time messages.
- There are two devices doing all the talking:
- The PLC: IP 172.21.2.1, MAC 30:b8:51:33:7e:c7. This is station 2.
- The IO device: MAC 4c:e7:05:4b:46:4b. With the lldp filter I could even read its name and type: it is a Siemens ET200SP (IM155-6PN/2 HF) and its ProfiNET name is "pniodispense". That is the IO block on top of the dispenser.

- The PLC and the device send a message to each other about every 2 milliseconds (so 500 times per second). Both directions use FrameID 0x8000.
- I did not see any pn_dcp messages. That makes sense, because the machine was already running in this capture. You only see pn_dcp when a device is powered off and on again. To capture that you would have to pull the power of the IO block for a moment, like the assignment says.

So the whole machine is controlled by these small messages, sent 500 times a second, with no protection on them.

Here is one real frame from the capture (PLC to IO device), so you can see what is inside:

```
Destination MAC : 4c:e7:05:4b:46:4b   (the ET200SP IO device)
Source MAC      : 30:b8:51:33:7e:c7   (the PLC, station 2)
EtherType       : 0x8892              (ProfiNET real time)
FrameID         : 0x8000              (cyclic IO data)
Status          : cycle counter present, data marked as valid
```

Screenshots

I added the three screenshots below from the capture to show how I got the results. To make them yourself: open the file in Wireshark and type the filter.

[Screenshot 1 - filter: pn_io - the list of ProfiNET messages between the PLC and the IO device]

[Screenshot 2 - click one frame and open it, so you see EtherType 0x8892 and FrameID 0x8000 and the data]

[Screenshot 3 - filter: lldp - the packet that shows the device is a Siemens ET200SP with the name pniodispense]

3. Which attacks have been done against ProfiNET (with sources)

Because the messages have no protection, researchers have found several attacks. These are real and written about:

- Scanning the network with pn_dcp. You send one request and every device answers with its name, type and IP. Now you know the whole machine.
- Spoofing with pn_dcp. You can rename a device or change its IP, which breaks the link with the PLC and the device goes offline.
- Man in the middle with ARP spoofing. You put yourself between the PC and the PLC and can read or change the traffic.
- Replay attack. You record the normal messages and send them again later. Because there is no protection, the receiver can believe the old (recorded) data.

- Fake messages / flooding (denial of service). You send your own 0x8000 messages faster than the real ones, or you flood the device so it loses the connection and stops.

For the full list of sources with titles, see the last part of this report.

4. How I want to attack the machine and my goal

My goal is to show that you can mess with the dispenser if you are on the same network. I want to show two things:

- Denial of service: make the IO device stop or go into error, so the dispenser does not work anymore.
- Replay/spoofing: make the PLC or the device believe data that is not true (for example that everything is fine, while it is not).

I can do this because I already have everything I need from the capture: the FrameID (0x8000), both MAC addresses, the IP addresses and the timing (2 ms). Nothing is encrypted, so I do not have to crack anything.

The plan would be:

1. Connect my laptop to the switch in the cabinet.
2. Record the normal pn_io messages (I already have them in the capture).
3. Send them again (replay), or send my own messages faster than the real ones.
4. Watch what happens on the HMI and in Wireshark.

Tools for this are normal and free: Wireshark to record, and tcpreplay or Scapy to send the messages again.

5. Trying the attack: replay (analysis of the capture)

To be clear about what I did: I only analysed the given capture file offline. I did not send any packets to the real Festo machine. A capture proves that the frames can be recorded and read, but it does not prove that the IO device really accepts messages that are sent again. A ProfiNET receiver can still reject frames, for example by checking the cycle counter, the connection it belongs to, or the timing. So I checked the capture to see how realistic a replay attack is (the attack surface), not to confirm it works.

What the capture shows:

- The frames are complete and readable. In the example frame in part 2 you can already see the source MAC, the FrameID 0x8000 and the data. Nothing is encrypted, so a recorded frame is also a frame you could send again.

- There is only a small freshness marker: a cycle counter in the status and a bit that says the data is valid. The receiver mostly watches that frames keep coming in time (the watchdog).
- The timing (every 2 ms) is easy to copy.

To really test the replay (on a test setup, not the running machine) you would:

- In Wireshark filter pn_io, then use File, Export Specified Packets to save only these frames.
- Replay that file with tcpreplay, or resend it with Scapy, keeping the same MAC, FrameID and 2 ms timing.
- Then check if the device acts on the old data or goes into error.

Honest conclusion for this part: the provided packet capture was analysed to assess the feasibility of a replay attack. The capture contains cyclic PROFINET IO frames with identifiable MAC addresses, FrameIDs and timing information. This suggests a potential replay attack surface. However, no packets were retransmitted to the physical Festo machine, so successful replay and its effects could not be experimentally confirmed.

Conclusion

The dispense station is controlled by ProfiNET messages that, in this setup, have no password and no encryption. Anyone who can plug into the switch in the cabinet can read them, copy them and in theory send them again. So the main risk is that someone with access to the network could disturb the machine or feed it false data.

What helps against this:

- Keep the OT network separate from the normal office network.
- Lock the switch ports and keep the cabinet physically locked.
- Use the newer PROFINET Security features. The PROFINET standard now has extra protection for the integrity and the authenticity of the communication (see PROFINET Security, PI). So protecting the messages themselves is possible on newer devices; the devices in this capture just do not use it.

Sources

- Pfrang, S. and Meier, D. (2018). Detecting and preventing replay attacks in industrial automation networks operated with PROFINET IO. Journal of Computer Virology and Hacking Techniques, volume 14. (available on ResearchGate / Request PDF)
- Akerberg, J. and Bjorkman, M. (2009). Exploring Security in PROFINET IO. 33rd IEEE International Computer Software and Applications Conference (COMPSAC), IEEE Xplore.
- Paul, A., Schuster, F. and Konig, H. (2013). Towards the Protection of Industrial Control Systems - Conclusions of a Vulnerability Analysis of PROFINET IO. DIMVA 2013, Springer.

- Mehner, S. and Konig, H. (2019). No Need to Marry to Change Your Name! Attacking Profinet IO Automation Networks Using DCP. DIMVA 2019 (BTU Cottbus-Senftenberg).
- PROFIBUS and PROFINET International (PI). PROFINET Security (Comprehensive Concept). https://www.profibus.com

(Please check the exact page numbers and the links in your library before handing in, these can differ per edition.)